

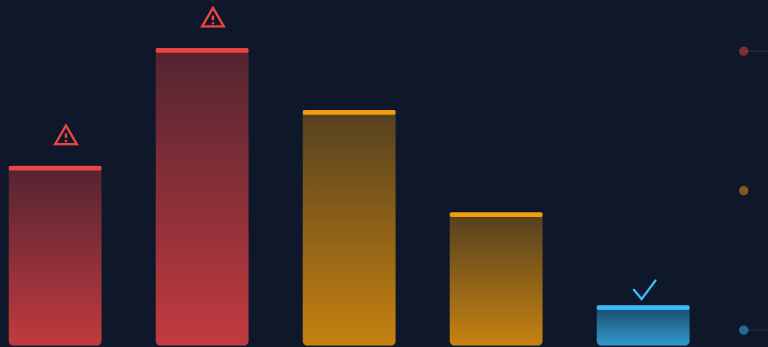


Your Backups Are Lying to You

Most Backups Fail When You Need Them Most. Verify Every Backup Before the Disaster.

The Backup Failure Crisis

Most Backups Fail. Most Attackers Target Them. Few Organizations Recover.



What is the longest window in the last 12 months during which any production system's backup was confirmed to actually boot and pass an application-level health check? If the honest answer is "we don't know" or "never," the rest of this deck is about what that gap costs and how to close it.

Veeam's own Data Protection Trends Report 2024 (n=1,200) supplies the supporting number: **fewer than 3 out of 5 servers (58%) are recoverable within stated expectations** in large-scale disaster tests. Only **13% of organizations** can orchestrate a successful full recovery during a disaster scenario, and only 32% believe they could recover from a small attack within a week.

The ransomware dimension turns the gap into an existential metric. Sophos's State of Ransomware 2024 (n=2,974) found that **94% of ransomware attacks now target backup infrastructure**, with **57% of those attempts succeeding**. Veeam's 2024 Ransomware Trends Report puts the targeting rate higher at **96%, with 76% of attempts compromising backup data**. When backups are compromised, the financial gap is brutal: a median recovery cost of **\$3M versus \$375K** when backups survive (8x).

Average ransomware recovery: **3.4 weeks** and **\$2.73M** excluding ransom. Average 2024 ransom payment: \$2M, a 5x increase from 2023's \$400K (Sophos 2024).

The question the rest of this deck answers: if attackers come for your backups and most succeed, what changes when verification stops being a quarterly checkbox?

The Testing Gap Nobody Talks About

One-Third Never Test. Of Those Who Do, 77% Find Failures.

The failure crisis is compounded by a testing crisis. Approximately **one-third of businesses never test their backups** (Computer Weekly). Of those that do test tape backups, **77% discover failures** (Pivotal IT). Veeam's 2025 Ransomware Trends Report found that **only 44% of ransomware response playbooks include backup verification procedures**, and **only 37% of organizations use a sandbox or quarantine environment during recovery** to confirm backups are clean before restoring (Veeam 2024).

These numbers describe an industry that treats backup as a write-only operation. Data goes in, nobody checks whether it comes back out. The cost of getting that wrong is the most expensive operational mistake on the modern balance sheet.

ITIC's 2024 Hourly Cost of Downtime Survey (n=1,000+ firms) found that **over 90% of mid-size and large enterprises report hourly downtime costs exceeding \$300,000**, and **41% report \$1M to \$5M per hour**. EMA Research and BigPanda measured average unplanned-downtime cost at **\$14,056 per minute**, rising to **\$23,750 per minute** for large enterprises. Siemens's 2024 True Cost of Downtime report puts unscheduled downtime at **11% of annual revenues across the world's 500 largest companies, \$1.4 trillion total, up from \$864 billion in 2019-2020**.

The next question is the obvious one: at \$14,056 a minute, what does a backup test schedule that runs continuously, not quarterly, do to that math?

Real Incidents That Prove the Point

When "Backup Completed Successfully" Becomes a Lie

The pattern across the three best-documented cases is the same: each organization's backup infrastructure was not insufficient, it was architecturally unable to survive the attack or accident it faced. Each of them believed their backups worked. None had verified that the backups would boot.

GitLab (January 2017). When an engineer accidentally deleted the production database, GitLab discovered that **all five of their backup and replication techniques were broken or misconfigured**. Automated pg_dump backups had been silently failing for weeks due to a PostgreSQL version mismatch. Failure-notification emails were rejected because of DMARC misconfiguration. The S3 backup bucket was completely empty. Azure disk snapshots had never been enabled. GitLab lost 6 hours of production data affecting 5,000 projects and live-streamed the panicked recovery on YouTube to 5,000 viewers. Every one of those five failure modes is detectable by a system that boots the backup, not one that reads a "success" flag.

Maersk (June 2017) was saved only by luck. NotPetya destroyed roughly **150 Active Directory domain controllers worldwide within minutes**. Both primary and backup infrastructure were wiped. The single surviving copy of their AD was on a server in Ghana that happened to be offline during the attack due to a power outage. Recovery required reinstalling **4,000 servers, 45,000 PCs, and 2,500 applications over 10 days, at a cost of \$250M to \$350M**.

Travelex (December 2019) illustrates how backup failure leads to corporate death. REvil ransomware encrypted their systems; incomplete and outdated backups forced the company to pay a **\$2.3M ransom**. Systems were offline for over two weeks, staff reverted to pen and paper in 1,200 branches, and the financial spiral, compounded by COVID, drove Travelex into administration (bankruptcy) by August 2020, costing 1,300 jobs.

The reader's next question: what are the named competitors actually doing about verification, and where does each of them stop short?

Competitive Landscape: The Verification Depth Gap

What Each Vendor Actually Boots, And What They Don't



Vendor	Boot Test	App-Level Test	Automated	Target Market
Veeam SureBackup	Full VM boot	Built-in + custom	Yes	Enterprise
Rubrik	DIY via API	Requires scripting	No	Enterprise
Commvault	Live mount	SQL/Oracle scripts	Yes	Enterprise
AWS Backup	Restore test	Custom Lambda	Yes	Cloud-native
Azure Backup	None	None	No	Cloud-native
Datto	Boot screenshot	PowerShell/bash	Yes	SMB/MSP
Zerto	Test failover	Via scripts	Yes	Enterprise DR

Veeam SureBackup is the most technically complete verification feature in the market. It boots VMs from backup in an isolated "Virtual Lab," performs heartbeat tests, runs application-specific checks, and scans for malware. The architectural constraint matters more than the feature list: SureBackup requires Enterprise+ licensing, demands substantial compute for Instant VM Recovery, is limited to VM workloads, cannot verify file-level backups, and ships with a resource-driven **default cap of 3 simultaneous VMs**. Verifying a 300-VM estate at 3 VMs per cycle is a 100-cycle process, not a continuous one.

Rubrik markets "recovery assurance" aggressively. Native verification is checksum-based and must be **manually enabled via CLI**. Application-level testing requires custom PowerShell workflows and REST API integration. Neither is a continuous boot test.

Next: the cloud-native and SMB markets, which split into "absent" and "screenshot-only."

Cloud Providers and the MSP Market

AWS Lags. Azure Is Absent. Datto Screenshots.

AWS Backup added restore testing in November 2023. It runs automated restore jobs and measures completion time, verifying that backups can restore, not that the restored systems work. Meaningful application-level validation requires building **custom Lambda functions**. A server that restores from backup but fails to boot, serve traffic, or connect to its database has not been recovered. It has been copied.

Azure Backup offers no automated verification capability at all. Microsoft's own guidance says to "periodically perform data recovery tests" but ships no tool to automate it. Recovery testing requires manual execution or custom Azure Automation runbooks. For the organizations running on Azure, backup verification is either a manual quarterly project consuming engineering days, or, more commonly, something that does not happen.

Commvault offers a multi-layered approach: CRC-based data verification every 24 hours, application validation for VMware VMs with SQL and Oracle scripts, and the newer **Cleanroom Recovery (launched 2024)** providing cloud-based isolated recovery environments on Azure. Cleanroom Recovery is positioned for cyber-recovery scenarios rather than routine verification: a disaster response tool, not a continuous assurance tool.

Datto/Kaseya pioneered automated screenshot verification in 2011. The system boots VMs from snapshots, captures boot screenshots, and applies image-recognition for pass/fail determination. It is included in all BCDR device subscriptions at no extra cost. The constraint is structural: **channel-only, appliance-dependent**, limiting reach to organizations working with MSP partners on Datto hardware.

The next question is regulatory: which of these gaps now triggers a fine or denied insurance claim?

Compliance and Insurance Now Demand Proof That Backups Work

Underwriters Price the Risk. Regulators Enforce the Failure.

The commercial layer has moved first. **At-Bay's InsurSec research found that effective backups decrease ransomware claim severity by 41%**, and organizations that fail to restore from backups face claims averaging **\$190,000 more** than those that succeed. Carriers now require encrypted, offline or air-gapped backups with documented proof of successful restore tests as conditions of coverage. The three biggest premium-reduction levers are MFA, EDR, and immutable/tested backups. Organizations implementing all three reduce premiums by **20% to 50%**. Approximately **41% of cyber insurance applications are denied on first submission** (Marsh McLennan 2024), with inadequate backup practices among the top rejection reasons.

Regulatory enforcement runs in parallel. **HIPAA** requires covered entities to maintain documented testing and revision procedures for backup and disaster recovery, with penalties reaching **\$2.13M per violation category per year**. Recent enforcement has set the precedent: **Albany ENT paid \$1M plus \$2.25M in mandated security investments** after a 2023 ransomware incident exposed inadequate testing. **Enzo Biochem settled for \$4.5M across multiple states**. **St. Margaret's Health in Illinois became the first hospital forced to permanently close** following a ransomware attack.

Compliance and Insurance Now Demand Proof That Backups Work (continued)

Other Regulators Have Moved In the Same Direction

GDPR requires both the ability to restore personal data in a timely manner and a documented process for regularly testing the effectiveness of those controls. Penalties reach **\$20M or 4% of annual global turnover**. **NIST SP 800-53 Rev 5** treats backup reliability testing and sampled test restoration as baseline controls for moderate- and high-impact systems, not optional enhancements.

ISO 27001:2022 requires backup copies to be maintained and regularly tested, with ISO 27002 guidance recommending monthly or weekly restore tests for critical systems. Auditors cite failure to test backups as the most common Annex A 8.13 finding. **SOC 2 Availability Criteria A1.3** requires regular testing of recovery systems. **PCI-DSS 4.0** requires annual DR plan testing and incident response plan review. **SEC Rule 17a-4** requires broker-dealers to maintain backup electronic recordkeeping systems; the SEC imposed **over \$1.1B in fines in 2023** for recordkeeping failures.

Each framework requires not just backup capability, but documented evidence that backup systems have been tested and confirmed functional. Organizations that cannot produce timestamped verification logs face nonconformity findings that block certification in industries where ISO 27001 is a procurement prerequisite.

The next question, for an architect, is the one auditors don't write down: who actually has the authority to modify or delete a snapshot, and what stops an attacker who has compromised the orchestrator?

How btrfs Snapshots Enable Continuous Verification

The Adversary Model: Who Can Modify a Snapshot, Who Can Delete One



Verification depth is bounded by the storage architecture beneath it. The adversary model frames the constraint clearly. Three actors can attempt to modify or destroy a snapshot: an attacker with root on the production host, an attacker who has compromised the backup orchestrator's credentials, and a malicious or coerced backup administrator. Bolt-on immutability (immutable flags, vault policies layered on traditional storage) defends against the first; the second and third defeat most products in the comparison table above. The structural question is whether snapshot integrity is a property the storage layer enforces, or a policy a hostable agent enforces.

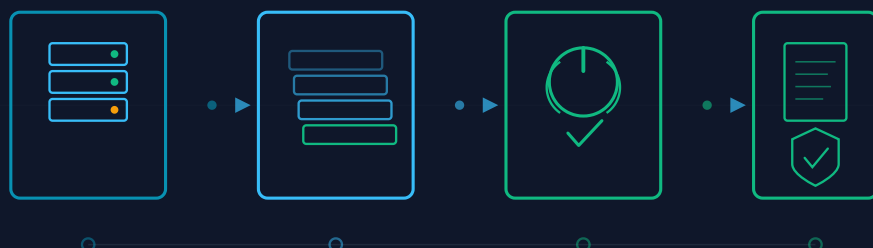
Copy-on-write changes the answer. Btrfs snapshots are not separate copies of data. They are read-only references to block pointers that the filesystem itself refuses to overwrite. Promoting a write into a snapshotted subvolume requires allocating new blocks; the original blocks remain reachable through the snapshot until the snapshot itself is deleted. Deletion is a metadata operation that requires the storage layer's authority, not the orchestrator's credentials. Stolen orchestrator tokens do not cross that boundary.

Verification scales with that geometry. Mounting a snapshot is a metadata operation, not a data copy, and completes in sub-seconds regardless of dataset size. A 10TB database snapshot and a 10MB config snapshot mount in the same time. Veeam SureBackup's 3-VM concurrency cap exists because each verification spins up a full VM instance from Instant Recovery; copy-on-write removes that bottleneck and makes whole-estate verification on every cycle economically rational rather than aspirational.

Retention follows the same property. Because copy-on-write writes only changed blocks, retention extends without proportional storage growth. SEC Rule 17a-4 requires **6-year retention** for broker-dealer records; HIPAA requires **retention for the life of the organization plus 6 years**. On traditional full-image backup, that retention horizon multiplies storage by the snapshot count. On btrfs, it grows with the changed-block delta. Ten snapshots of a 1TB system can fit in 10GB to 50GB of incremental storage, not 10TB.

Verification Architecture: The Boot-and-Verify Pipeline

Capture, Snapshot, Boot-Test, Report. Each Stage Produces Audit Evidence.



The pipeline transforms every backup from an unverified data copy into a documented, proven recovery point through four stages. **Capture** uses btrfs's copy-on-write architecture to take point-in-time filesystem snapshots at minute-level intervals. Snapshots are purely metadata operations and complete in sub-seconds regardless of dataset size, because no data is actually copied. Only metadata pointers are created.

Snapshot stores those captures with block-level deduplication. Because btrfs writes changed data to new locations rather than overwriting existing blocks, multiple snapshots share the vast majority of their underlying data blocks. This is the storage economics that makes minute-level capture economically viable, where traditional full-copy approaches make it prohibitive.

Boot-and-verify is where the architecture diverges from the comparison table. Each snapshot is mounted and booted in an isolated environment. The system confirms that the operating system loads, that critical services start, that databases accept connections, and that application-level health checks pass. This is recovery testing, not a checksum comparison or a file-count tally. Boot-level verification catches the failures that metadata checks miss by definition.

Report generates timestamped, audit-ready documentation: snapshot timestamp, boot confirmation, service status, application health check results, verification duration. The output stream satisfies the evidence requirements of:

- **SOC 2 Availability Criteria A1.3** (regular testing of recovery systems)
- **HIPAA 45 CFR 164.308(a)(7)** (contingency plan testing)
- **ISO 27001:2022 Annex A 8.13** (timestamped restore logs)
- **GDPR Article 32(1)(d)** (regular testing of security measures)

Continuously, without manual intervention, on every snapshot, not on a quarterly sample.

A Backup You Haven't Tested Is Not a Backup. It's a Hope.

Rediacc Verified Backups: the only backup that proves it works, before you need it.

Automatic boot-and-verify testing on every backup. Minute-level RPO via btrfs snapshots.

Compliance evidence for SOC 2, HIPAA, GDPR, ISO 27001, and cyber insurance, on autopilot.

rediacc.com/verified-backups

rediacc.com

One platform. Verified recovery. Documented proof.